

Stack 07 remediation and first-review retrospective — 2026-09-24

Scope, ownership and review identity

This is the full retrospective for the first Stack 07 Copilot round, including the defects found during remediation and predecessor integration. The main firmware worktree owns the SOP, master ledger and `audit-claims/715-07/OWNER.md`; agent 2 retains this claim. The earlier intake document is historical evidence, not the current status.

The owner authorized one immediate request on code-bearing [PR #837](#). Request time: 2026-09-24T02:20:47Z. [Review 5298993214](#) arrived at 02:29:47Z on historical head `4695a11444fa6a3bb990e59d000b8149bc5b74f3`, against historical Stack 06 base `b771669ba842d83790a69b6132f63cea82e5a861`. Its verdict was **Changes recommended**, effort Lite, with **13 comments: 11 high, one medium, one low**. The preliminary triage incorrectly read “11” as the total; this report corrects that counting error. The body repeats the same policy, binding, authentication, array and header concerns; it supplies no separate actionable finding beyond these 13 comments.

There has been **one Stack 07 request and no second request**. The owner requires remediation and this retrospective before considering any further round. The delivered review is historical and must never be represented as a review of the corrective candidate.

What went wrong

The failure was substantive. Reviewed calldata was not committed to the bytes eventually signed, a certified typed-data program could omit later display fields, and nested fixed-array validation was wrong. Header guards, direct-call range validation and the release narrative also escaped preflight. Parser unit coverage and successful links did not establish the complete signing contract.

The implementation distributed authority over several passes: authenticated definition replay, ABI or typed-data traversal, UI confirmation, and final signing. Tests validated each piece but did not prove that the values and schemas stayed identical between pieces. They also did not exercise a real signed catalog through every host/device continuation and cancellation path. That gap explains both the review's calldata finding and the additional schema, ownership, domain and identity defects found while repairing it.

The first request reviewed a historical branch while the predecessor audit was still changing. That made its result useful for discovery but insufficient for acceptance. Reconciliation later introduced a concrete interaction failure: Stack 06's stricter dispatcher aborted the new Stack 07 continuation messages. The ordinary host suite passed while six of seven new authenticated protocol tests failed. Only running the complete new workflow on the integrated predecessor exposed it. Those tests are now registered in the repository CI runner.

There was also an earlier wrong-PR review request during the Stack 05/07 transition. That was an execution error, not Stack 07 coverage. Before any future authorized request, record the explicit PR number, immutable head, actual base, claim owner and code-bearing diff together. This review budget does not authorize an automatic retry.

Disposition of every review comment

Comment	Disposition	Change or technical basis and executed evidence
4089197347	Fixed	The EIP-712 include guard now encloses every public declaration. The native test translation unit includes the header twice and compiles.
4089197364	Fixed	SHA-256 commits the validated selector and calldata. Every display replay and the actual signing pass must match it. Native chunk-boundary tests and a host mutation on the fourth/signing pass reject changed bytes.
4089197391	Fixed	Array-level count is checked before indexing the wire array. <code>TypeNameRejectsArrayCountPastWireCapacity</code> covers the direct helper boundary.
4089197421	Fixed	Frames retain every declared dimension and consume the outermost, last-written dimension first. <code>NestedFixedArrayChecksOuterAndInnerDimensions</code> rejects wrong inner and outer lengths; disabling this check makes the test fail.
4089197450	Fixed	Only the canonical singleton empty root tuple is accepted; malformed empty nested structures remain invalid. ABI tests and the real selector-only signing host test pass.

Comment	Disposition	Change or technical basis and executed evidence
4089197469	Refuted	Adding a bounded nonnegative child count to a negative int32 value cannot overflow either signed bound: the minimum is INT32_MIN and the maximum is below the bounded count. A still-negative result is refused. ExtremeNegativeIndexFailsWithoutArithmeticWrap checks INT32_MIN.
4089197498	Refuted as stated	The signed Merkle leaf hashes the entire program, including its identity header. Certificate scope must equal the signed chain and its public key must equal the loaded runtime key that verifies the signature. SignatureAuthenticatesHeaderAndRuntimeKeyContext signs a real envelope and rejects changed epoch, scope and key; AdvancedMode-off also fails. Host certificate alias is never displayed as authority; the approved runtime alias/fingerprint is used.
4089197515	Fixed, same root cause as 4089197450	The streamed catalog validator accepts the same canonical empty root. Catalog authentication and selector-only host signing cover both layers.
4089197543	Policy clarification	Ordinary streamed EIP-712 validates, displays and hashes every leaf and remains available in normal mode. Runtime-certified annotations and blind precomputed hashes require AdvancedMode. The PR's blanket "streaming behind AdvancedMode" description was inaccurate; the report preserves the actual established policy rather than disabling ordinary disclosed signing.
4089197567	Fixed	Every certified typed field is selected and confirmed. Repeated message walks must preserve the domain/message digest and schema commitments before signing. Host tests require both fields, identical ordinary/certified signatures, refusal of changed second-pass values, and cancellation at either field.
4089197583	Same policy clarification as 4089197543	The certified entry is AdvancedMode-gated; the ordinary fully disclosed stream is a separate contract. Native policy/authentication and host ordinary/certified tests cover the distinction.
4089197600	Fixed	ethereum_signing_init() again calls the full chain-ID validator. DirectSigningEntryRejectsChainIdAboveMaximum exercises the direct entry in addition to the FSM guard.
4089197619	Fixed	The alpha handoff is explicitly historical; it distinguishes the bounded 7.15 extraction from the complete alpha design. Correction originated in 1679e17dc.

These are nine fix comments covering eight distinct roots, two overlapping policy comments, and two technical refutations. Resolution means a pushed fix or a reasoned reply, not deleting or moving an anchor. GitHub thread status is recorded separately in the publication receipt.

Additional defects found and repaired locally

Defect	Prior behavior	Repair and evidence
Schema replay substitution	The host could change a named schema between discovery, type hashing and value traversal.	Canonical schema digests are retained and checked throughout the session. RefusesSchemaChangesAfterDiscoveryAndHashing fails when that protection is removed.
ABI program-view lifetime	Streaming state retained a pointer to a temporary caller program view.	The stream owns the small view by value; nodes remain owned by the workflow loader. Native coverage overwrites the caller view after initialization. Layout padding was reduced to retain the existing bounded workflow budget.
Signed domain constraints ignored	Matching type, chain and contract did not enforce descriptor name/version/salt or absence assertions.	The loader retains signed domain operations/literals; validated stream facts must satisfy each supported constraint before certified message review. Native equality/absence tests and host name/version/salt substitutions fail closed.
Runtime source and intent absent	Authenticated alias existed but was not shown; typed-data intent, including intent-only programs, could be omitted.	Show the approved runtime alias/fingerprint, "NOT verified by KeepKey", then intent. Preserve ordinary review. Host screen counts, cancellation cases and inspected OLED frames cover both fields and intent-only programs.
Integrated dispatch and cleanup	Stack 06's default abort rejected valid new continuations; EIP-712 stream cancellation was not part of common signing cleanup.	Phase-specific continuation admission; session boundaries and auto-lock clear typed state. Only validated active-workflow requests renew the deadline. Actual receive-path tests prove typed progress renews, GetFeatures polling eventually locks, and stale acknowledgements fail.

Main repair commits are 590d9901b and ec4c42509. Candidate code head is 34a36e700, integrating Stack 06 corrective head 8ed653517a63278891353bcf939a9c3108feacb2. Stack 06 acceptance remains its owner's decision; integration alone does not confer acceptance.

Security contract and falsification matrix

State/value and origin	Observer, variant and phases	Allowed and forbidden outputs; equivalent representations	Assertion/counterexample
Host calldata bytes	Firmware parser, user OLED, signer; full only; parse/review/replay/sign	Sign only the reviewed exact selector+arguments. Same ABI shape or formatted value is not sufficient equality.	Change a value only in the actual signing pass; reject. Change chunk boundaries without changing bytes; accept. Disable digest comparison; native test fails.
Host typed schema and values	Type-hash walker, user, signer; full only; discovery/hash/repeated fields	One canonical schema per name and one domain/message digest. Different schema or value encodings must not change signed meaning after consent.	Mutate named schema and second-pass message; reject. Disable each commitment independently in the focused mutation run; corresponding assertions fail.
Signed descriptor identity/domain	Catalog verifier and user; full only; preload/match/UI	Program header authenticated by leaf hash; runtime scope/key checked; signed equal/absent constraints enforced. Host alias cannot impersonate approved source.	Real signature fixture with changed epoch/scope/key; name/version/salt substitution; exact runtime alias observed on OLED.
Runtime annotations and consent	User and signer; full only; source/intent/every field	Source/warning/intent and every field precede signature; annotations never remove ordinary review. Rejecting any protected screen returns no signature.	Decline source, warning, intent and each field; fresh ordinary session succeeds. Certified and ordinary signatures match for unchanged input.
Untrusted array counts/indices	Parser memory and signer; full only; type formatting/nested traversal	Wire bounds and every fixed dimension enforced before use. INT32_MIN must remain a rejected index.	Oversized count, wrong inner/outer fixed dimension, extreme negative index; dimension mutation test fails.
Workflow timer and state	Device lock/session state; full signing, both-product shared cleanup	Only validated progress renews. GetFeatures, malformed/stale acknowledgements, abort and unrelated commands cannot keep or revive signing.	Actual receive callback with valid typed progress near expiry, repeated polling to lock, session boundary loop and stale continuation refusal. Existing shared malformed/tiny receive tests run in both variants.
Product separation	Firmware link/message map; BTC-only	No ERC-7730 or streamed EIP-712 signing surface in BTC product.	Both ARM links, BTC native/host suites; new protocol suite explicitly skips BTC. Physical device execution remains unavailable.

The separate falsification pass deliberately removed calldata commitment, typed digest commitment, schema equality and inner fixed dimensions. All four selected tests failed, then the original source bytes were restored and rebuilt. The final full native suite passes with the protections restored. Negative-control XML/logs are preserved; failing a mutation is expected evidence, not a product failure.

Validation record and limits

Pinned builder: kktech/firmware@sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2. Host pin: b745562be6a13cc83b2a547d7ef86637f4556dbb. Candidate firmware/native results: full 598 passed; BTC 134 passed. Full and BTC ARM products link. RAM gap between _ebss and _stack: full 18,900 bytes, BTC 39,140 bytes, both above the 16,384-byte static floor. This is not a measured worst-case physical stack watermark.

Seven authenticated host regressions passed after the dispatch repair with OLED capture. Inspected images show “Audit signer (0C2C88B9)”, “NOT verified by KeepKey”, “Audit action”, “First value 42” and “Second value 7”. These use a public test mnemonic and throwaway signing key, not production credentials. The final broad host result and exact evidence hashes are recorded in the accompanying candidate receipt.

Failures retained in the evidence history: the initial Docker read-only/disk outage prevented execution; an initial mutation-script pattern assertion failed before mutations ran; reused native flash state failed a recovery precondition while fresh isolated runs passed; integrated authenticated contracts initially failed 6/7 before dispatch repair; and a final host invocation used `KK_STAGED_MISSING_CAPABILITIES` instead of the workflow's `KK_RELEASE_MISSING_CAPABILITIES`. The incorrect environment did not activate staged exclusions and produced later-block failures; corrected results must not overwrite that evidence or relabel excluded capabilities as covered.

No physical device was flashed, no production signing was performed, and no release was promoted. Full ERC-7730 v2 conformance and later release-stack capabilities remain outside this bounded extraction. Hosted exact-head CI and predecessor acceptance are separate statuses from these local checks. A historical green result or a resolved thread is never a current-head clean review.

Hosted qualification correction

First corrective hosted run 35962710863 on e46aae5fd passed all native, static, ARM and BTC integration jobs, but full integration stopped at the screenshot audit: `test_clearsign_erc20_approve_unlimited` passed its refusal assertion and captured zero screens, while the report incorrectly declared two. The frozen local preflight had inspected the new Stack 07 frames and JUnit validation, but did not replay the full existing screenshot declaration set after enabling `erc7730-runtime-review`. That omission belongs to this audit, not to an infrastructure explanation.

The firmware already refuses unlimited approval before any `ButtonRequest`. Published host correction 1d42a1fa401129da292a8b0fe4f6dc9bee727117 describes that exact screenless contract, removes the invalid full-sequence claim, and strengthens the actual wire test to require immediate Failure with no intervening `ButtonRequest`. Nearby generated report prose now correctly states AdvancedMode ON with annotations additional to ordinary raw review. No firmware policy, assertion or screenshot gate was weakened. Seven focused refusal/report tests pass; replaying the corrected screenshot audit against the actual hosted artifact passes. Firmware source remains identical to the locally validated implementation. New-pin final hosted CI is recorded in the PR receipt.

Prevention: before the combined matrix, run the report-required screenshot audit across all newly enabled legacy cases, not only newly authored protocol tests. A successful wire test with no frames is valid only when the report declares a refusal contract and the wire assertion prohibits intervening approvals.

Prevention and next-round discipline

- Pin the claim, PR, actual predecessor and immutable head before any external request. Verify the diff is code-bearing and belongs to the named block.
- Write a property matrix across parse, replay, display, signing, failure and restart before treating unit counts as security evidence.
- Require at least one real authenticated protocol fixture for each new signing path, including every display field, an alternate-pass mutation and user decline. Keep these fixtures in the CI runner.
- On predecessor changes, inspect dispatch admission, shared abort routines, timers and retained state explicitly. Run the new workflow on that exact integration before freezing evidence.
- Freeze source before the expensive matrix; use the exact workflow capability variable and list every skip. Preserve failed runs and explain the correction.
- Keep report language aligned with policy: ordinary disclosed streaming, runtime-certified annotations and blind hashes are distinct contracts.
- Do not request another review to discover whether an untested repair worked. Complete the local checks, full retro, pushed dispositions and preflight first; then obtain the owner's explicit authorization for any further round.

Completion states

Implemented: confirmed code defects and additional integration findings repaired. Targeted behavior: native and seven protocol cases pass. Adversarial checks: four negative controls detected the removed protections. Integration: final full/BTC native and ARM complete; broad host results tracked in the candidate receipt. External review: one historical review delivered with findings; no current-head review requested. Findings dispositioned: technical dispositions above, publication/thread closure tracked separately. Release accepted: **no**.

Later predecessor reconciliation — Stack 06 `ff956077f`

This section was added after the complete first-round retrospective. Stack 06 moved from `8ed653517` to `ff956077f` with a global ERC-20 allowance guard and three native regressions; its audit remains separately owned and its final review checkpoint is still open. Stack 07 merged the new head without conflict. Source inspection found an interaction the earlier Stack 07 tests could not cover: certified calldata begins with only four selector bytes, while the new predecessor policy needs the complete 68-byte approval prefix before any confirmation. A certified `approve(address,uint256)` could otherwise show runtime annotation screens and then fail at the ordinary signing entry.

The bounded certified path now refuses every approval selector immediately after matching the preloaded definition and before definition replay or annotation screens. The preload is cleared. A new real signed-envelope host regression requires zero `ButtonRequests` and the explicit failure, then proves a finite 68-byte ordinary approval still reaches signing. This is deliberately narrower than supporting certified approval: the current selector-only continuation cannot satisfy the predecessor's pre-review allowance policy. A future implementation would need to validate the full prefix before UI and bind those exact bytes to the signing stream.

The updated report/receipt records full, BTC, ARM, host, protocol, OLED and SRAM results against this merged tree. Earlier review `5298993214` and its dispositions remain historical; this merge is not covered by that review. No second Copilot request follows from adding this section.